

Nikto — Practical Tool Guide

Scan a web server, handle ports and TLS, send traffic through Burp, save reports, and manually verify findings.

➤ Abdullah Nasser Almsan — Personal Pentest Reference

Usage note: Nikto options can vary by version. The guide targets modern Nikto 2.6.x style usage; check - Help locally for advanced options.

NMAP

Find HTTP ports

NIKTO

Scan the server

BURP

Review requests

VERIFY

Confirm manually

Contents

1. Basic web-server scan
2. Multiple ports and targets
3. Proxy through Burp
4. Headers and reports
5. Reading findings

1. Basic web-server scan

Nikto checks web-server configuration, files, and known weakness indicators.

KALI TERMINAL — Default port

```
nikto -h http://[TARGET]
```

KALI TERMINAL — Specific port

```
nikto -h [TARGET] -p 8080
```

KALI TERMINAL — Full HTTPS URL

```
nikto -h https://[TARGET]:443/
```

KALI TERMINAL — Force SSL/TLS

```
nikto -h [TARGET] -p 443 -ssl
```

2. Multiple ports and targets

Useful after discovering several HTTP services.

KALI TERMINAL — Multiple ports

```
nikto -h [TARGET] -p 80,8080,443
```

Use Nmap first to determine which ports actually serve HTTP/HTTPS instead of scanning everything blindly.

3. Proxy through Burp

Observe Nikto requests in Burp HTTP history.

KALI TERMINAL — Direct proxy

```
nikto -h http://[TARGET] -useproxy http://127.0.0.1:8080
```

With the proxy, you can inspect the request that produced a finding instead of trusting a single result line.

4. Headers and reports

KALI TERMINAL — Additional header

```
nikto -h http://[TARGET] -Add-header "X-Test: 1"
```

KALI TERMINAL — Save output

```
nikto -h http://[TARGET] -o nikto-report.txt
```

KALI TERMINAL — Help

```
nikto -Help
```

Report format behavior can depend on the Nikto version and output options; check `nikto -Help` on the installed version.

5. Reading findings

Note: A Nikto finding is not proof of exploitation.

Treat a result as a lead: open the path manually, review headers/response details, and research the version or CVE when one is provided.

Note: Web scanners can generate many requests. Do not use them against external sites without clear authorization.

Prepared as a quick-reference companion to the canonical Arabic guide. Use only in labs or systems you are explicitly authorized to test.

References:

<https://github.com/sullo/nikto/wiki/Basic-Testing>

<https://github.com/sullo/nikto/wiki/Using-a-Proxy>

<https://github.com/sullo/nikto/wiki/Annotated-Option-List>